

Computer Security: Principles and Practice

User Authentication Access Control

Chapter 3 and Chapter 4



TYPES OF AUTHENTICATION

There are different **types of authentication**, each with a distinct focus:

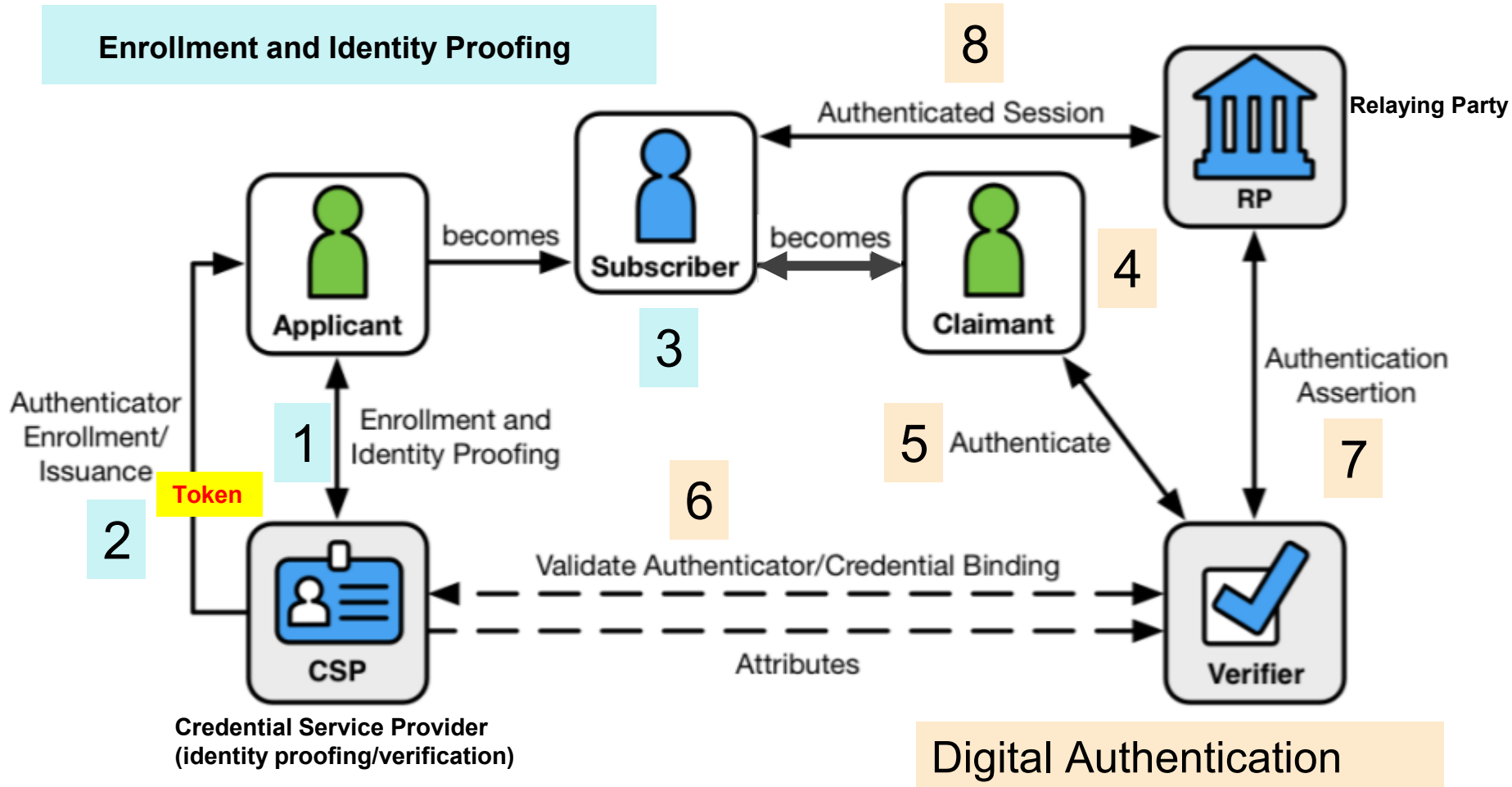
Type	Focus	Example
Message Authentication	Securing data in transit	MAC in payment request
User Authentication	Verifying user identity	Logging in with MFA
Data Authentication	Verifying data integrity	Hash checksum for a downloaded file
Device Authentication	Authorizing devices	VPN certificate authentication
API Authentication	Verifying application access	OAuth for a mobile app
Network Authentication	Securing network access	802.1X on a corporate Wi-Fi
Application Authentication	App-level access control	Logging into a cloud app via SSO
Entity Authentication	Authenticating organizations	Digital certificates for secure emails
Process Authentication	Authorizing system processes	Only running signed software

USER AUTHENTICATION

“The process of **establishing confidence** in **user identities** that are presented **electronically** to an information system.”



DIGITAL IDENTITY MODEL



DIGITAL IDENTITY MODEL

- **Enrollment and Identity Proofing**

1. **Applicant** starts the process with the **Credential Service Provider (CSP)**.
2. The CSP performs **identity proofing** and issues **authenticators**.
3. Once identity proofing is successful, the **applicant becomes a subscriber**.

- **Digital Authentication**

4. The **subscriber becomes a claimant** when they attempt to authenticate.
5. The claimant uses their **authenticator** to prove identity to a **verifier**.
6. The **verifier validates the credential** and interacts with the **CSP** for attribute verification.
7. The verifier provides an **authentication assertion** to the **Relying Party (RP)**.
8. If authentication is successful, an **authenticated session** is established between the RP and the subscriber.

DIGITAL IDENTITY MODEL

Process:

- **Identity Proofing** is the process of verifying the subject's association with his or her real-world identity.
- **User Digital Authentication** is The process of establishing confidence in user identities that are presented electronically to an information system

Entities:

- **Credential Service Providers (CSPs)** perform certain enrollment, identity proofing and issuance processes.
- **Verifier** is the party that verifies the claimant's identity.
- **Relying Parties (RPs)** depends on the CSP and the verifier to assert information about the subscriber.

Personas

- **Applicant** is the party to be proofed.
- **Subscriber** is an applicant that has successfully completed the proofing process.
- **Claimant** is the party to be authenticated.

DIGITAL IDENTITY MODEL

- **Enrollment Identity Proofing**

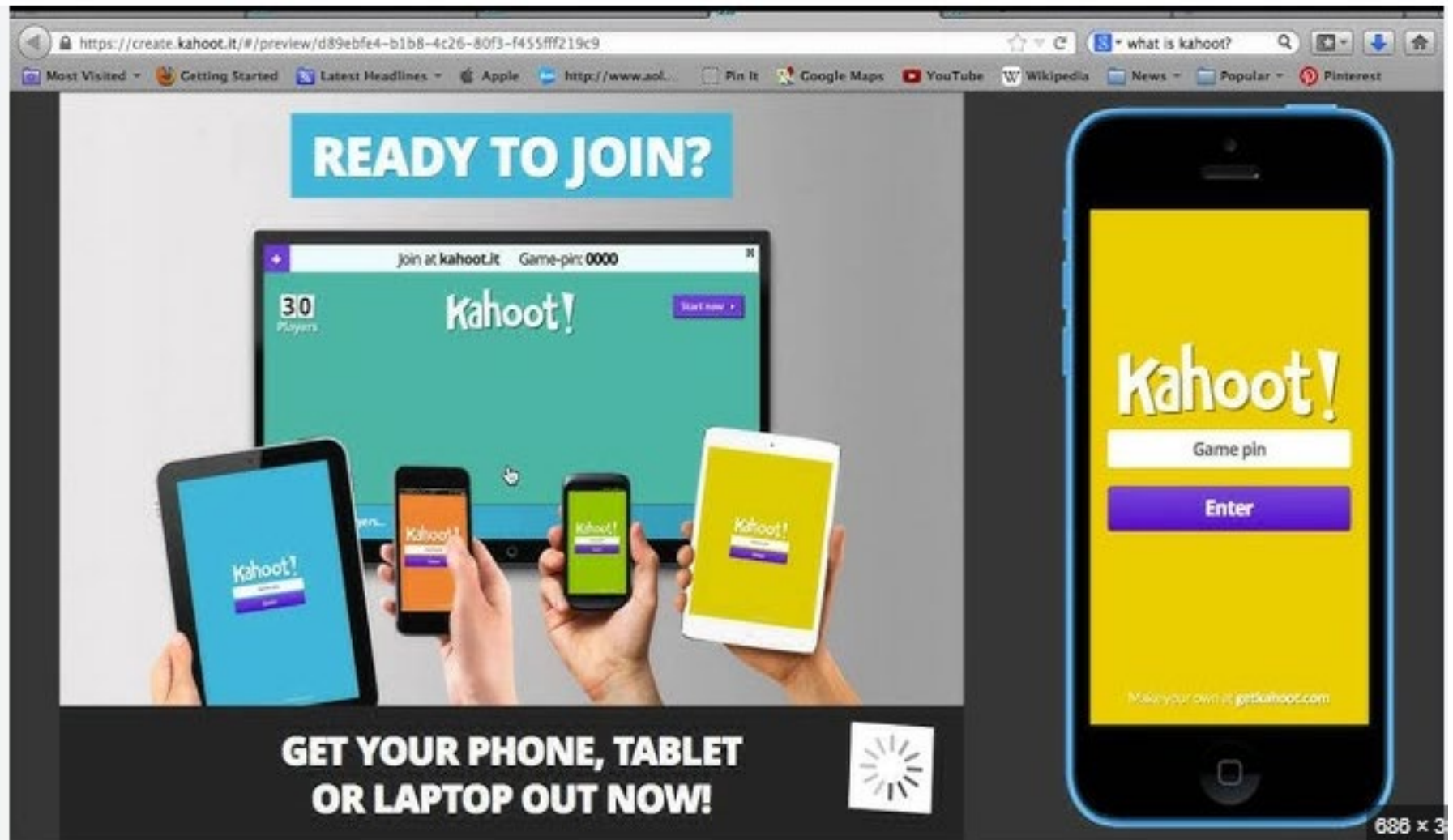
- 1) The applicant applies to the **CSP** to begin the enrollment and identity proofing processes.
- 2) The CSP performs **identity proofing** on the applicant. If the proofing is **successful**, the applicant will be elevated to the level of a **subscriber**.
- 3) The CSP and the subscriber will then establish **authenticator(s)** and a **corresponding credential**.
- 4) The CSP will then maintain the credential, its status and the collected enrollment data at a minimum for the lifespan of the credential. Meanwhile, the subscriber will maintain their authenticator(s).

DIGITAL IDENTITY MODEL

- **Digital Authentication**

- 1) The subscriber will be referred to as a **claimant** as they use an **authentication protocol** to prove possession and control of their authenticator(s).
- 2) The verifier will interact with the CSP to validate a credential that will **bind the subscriber's identity to their authenticator(s)** and to obtain **claimant attributes where needed**.
- 3) The CSP or verifier gives the **RP** an assertion about the subscriber. The RP will use that information to determine whether to authorize access to the subscriber.
- 4) If an authorization is **granted**, an authenticated session will be established between the RP and the subscriber.

Kahoot!



The image displays the Kahoot! website interface within a web browser window and a mobile app interface on a smartphone.

Website Interface (Left):

- URL:** <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>
- Search Bar:** "what is kahoot?"
- Navigation Bar:** Most Visited, Getting Started, Latest Headlines, Apple, http://www.aol..., Pin It, Google Maps, YouTube, Wikipedia, News, Popular, Pinterest.
- Main Content:**
 - Header:** "READY TO JOIN?"
 - Central Image:** A laptop screen showing the Kahoot! game interface with "30 Players" and "Game-pin: 0000". Below the laptop, four hands hold up a tablet and three smartphones, all displaying the Kahoot! app interface.
 - Bottom Text:** "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!"
 - Icon:** A circular loading icon.

Mobile App Interface (Right):

- Background:** Yellow.
- Logo:** "Kahoot!" in white.
- Input Field:** "Game pin" with a white border.
- Button:** "Enter" in white text on a purple background.
- Footer:** "Make your own at getkahoot.com"

686 x 3

What is the primary role of the Credential Service Provider (CSP) in identity proofing?

- A) To authorize access to a system for the subscriber
- B) To verify an applicant's identity and issue credentials**
- C) To act as an authentication factor for the subscriber
- D) To store and manage all subscriber passwords

What does a verifier do in the authentication process?

- A) Issues new credentials to claimants
- B) Stores authentication factors for the subscriber
- C) Validates credentials and confirms claimant attributes**
- D) Grants final authorization to the subscriber

At what stage does an applicant become a subscriber in the identity proofing process?

- A) When the CSP successfully verifies their identity**
- B) When they receive their first authentication request
- C) When they request access from the relying party (RP)
- D) When they log in for the first time

What is the key difference between an applicant and a claimant in the identity proofing and authentication process?

- A) An applicant has already been verified, while a claimant has not
- B) An applicant is seeking proofing, while a claimant is proving their identity during authentication**
- C) An applicant is authorized by the RP, while a claimant is not
- D) There is no difference; the terms are interchangeable

Which of the following best describes the relationship between a subscriber and their authenticator(s)?

- A) The CSP retains ownership of all authenticators
- B) The subscriber maintains possession of their authenticator(s)**
- C) Authenticators are only necessary during initial enrollment
- D) The RP manages the subscriber's authenticators

Which of the following is a key responsibility of the CSP after issuing credentials?

- A) Managing the authentication session between the RP and subscriber
- B) Maintaining the credential's status and enrollment data throughout its lifespan**
- C) Granting final authorization for all subscriber requests
- D) Storing subscriber authenticators for future use

What role does the Relying Party (RP) play in authentication?

- A) It directly verifies a claimant's credentials
- B) It issues credentials and manages authentication factors
- C) It receives assertions from the CSP or verifier to authorize access**
- D) It proof-checks the CSP's decision before authentication

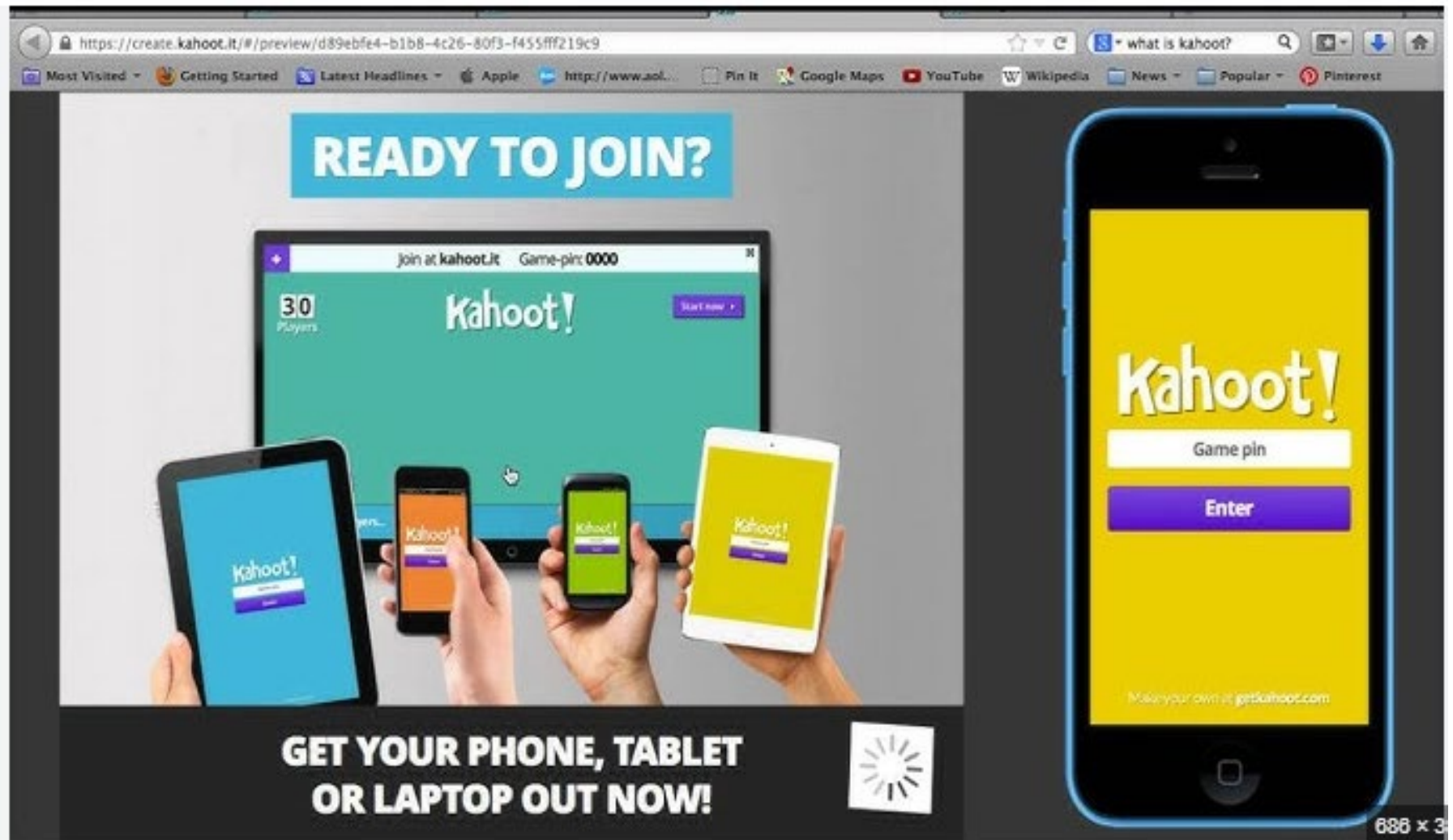
If a subscriber loses control of their authenticator, what should happen next?

- A) The RP automatically denies all access attempts
- B) The verifier should reissue the original credentials
- C) The CSP should revoke the credential and initiate re-proofing**
- D) The subscriber can continue using their credential until it expires

THE FOUR MEANS OF AUTHENTICATING USER IDENTITY ARE BASED ON:

- Something the individual **knows**
 - Password, PIN, answers to prearranged questions
- Something the individual **possesses (token)**
 - Smartcard, electronic keycard, physical key
- Something the individual **is (static biometrics)**
 - Fingerprint, retina, face
- Something the individual **does (dynamic biometrics)**
 - Voice pattern, handwriting, typing rhythm (behavioral biometric)
 - Requires sophisticated hardware/software

Kahoot!



The image displays the Kahoot! website interface within a web browser window and a mobile app interface on a smartphone.

Website Interface (Left):

- URL:** <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>
- Search Bar:** "what is kahoot?"
- Navigation Bar:** Most Visited, Getting Started, Latest Headlines, Apple, http://www.aol..., Pin It, Google Maps, YouTube, Wikipedia, News, Popular, Pinterest.
- Main Content:**
 - Header:** "READY TO JOIN?"
 - Central Image:** A laptop screen showing the Kahoot! game interface with "30 Players" and "Game-pin: 0000". Below the laptop, four hands hold up a tablet and three smartphones, all displaying the Kahoot! app interface.
 - Bottom Text:** "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!"
 - Icon:** A circular loading icon.

Mobile App Interface (Right):

- Background:** Yellow.
- Logo:** "Kahoot!" in white.
- Input Field:** "Game pin" with a white border.
- Button:** "Enter" in white text on a purple background.
- Footer:** "Make your own at getkahoot.com"

686 x 3

Which of the following authentication factors is classified as "Something the individual does (dynamic biometrics)?"

- A) Retina scan
- B) Smartcard
- C) Typing rhythm
- D) PIN

Which authentication method is considered **least susceptible** to being shared or stolen?

- A) Password
- B) Handwriting pattern
- C) Smartcard
- D) PIN

Which of the following is **not** an example of "Something the individual possesses?"

- A) Electronic keycard
- B) Physical key
- C) Fingerprint
- D) Smartcard

A system that verifies a person based on their **retina scan** falls under which authentication category?

- A) Something the individual possesses
- B) Something the individual knows
- C) Something the individual does
- D) Something the individual is

Q1: Match the authentication factor to its correct category

Authentication Factor	Category
A) Password	1) Something the individual is
B) Smartcard	2) Something the individual does
C) Typing rhythm	3) Something the individual knows
D) Retina scan	4) Something the individual possesses

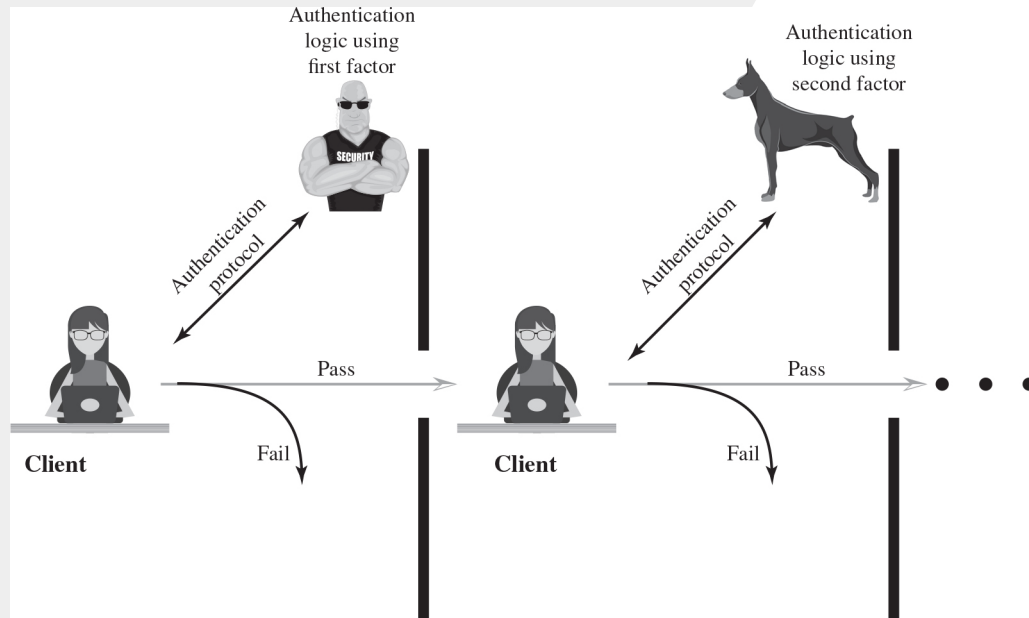
Q2: Match the authentication method to its potential security weakness

Authentication Factor	Security Weakness
A) PIN	1) Can be easily stolen or guessed
B) Face recognition	2) Can be spoofed with photos/videos
C) Smartcard	3) Can be lost or stolen
D) Voice pattern	4) Can be manipulated with deepfake AI

Q3: Match the biometric authentication method to its unique challenge

Authentication Factor	Category
A) Fingerprint	1) Can be affected by illness or noise
B) Retina scan	2) Requires special hardware
C) Voice recognition	3) Can be affected by injury or dirt
D) Handwriting pattern	4) Changes over time due to aging

MULTIFACTOR AUTHENTICATION



RISK ASSESSMENT FOR USER AUTHENTICATION

Three separate
concepts:

```
graph TD; A((Three separate concepts:)) --- B((Assurance Level)); A --- C((Potential impact)); A --- D((Areas of risk));
```

Assurance Level

Potential impact

Areas of risk

ASSURANCE LEVEL (1 OF 2)

- Describes an organization's degree of certainty that a user has presented a **credential** that refers to his or her identity
- More specifically is defined as:
 - The degree of confidence in the vetting process used to establish the identity of the individual to whom the credential was issued
 - The degree of confidence that the individual who uses the credential is the individual to whom the credential was issued

ASSURANCE LEVEL (2 OF 2)

- **Four levels of assurance**

- **Level 1**

- **Little** or **no** confidence in the asserted identity's validity
- Example: A consumer registering to participate in a discussion at a company's web site discussion board

- **Level 2**

- **Some** confidence in the asserted identity's validity
- Some sort of secure authentication protocol needs to be used

- **Level 3**

- **High** confidence in the asserted identity's validity
- Example: A patent attorney electronically submits confidential patent information to the U.S. Patent and Trademark Office

- **Level 4**

- **Very** high confidence in the asserted identity's validity
- Example: A law enforcement official accesses a law enforcement database containing criminal records.

POTENTIAL IMPACT

- **Low**

- An **authentication error** could be expected to have a **limited** adverse effect on organizational operations, organizational assets, or individuals

- **Moderate**

- An **authentication error** could be expected to have a **serious adverse** effect

- **High**

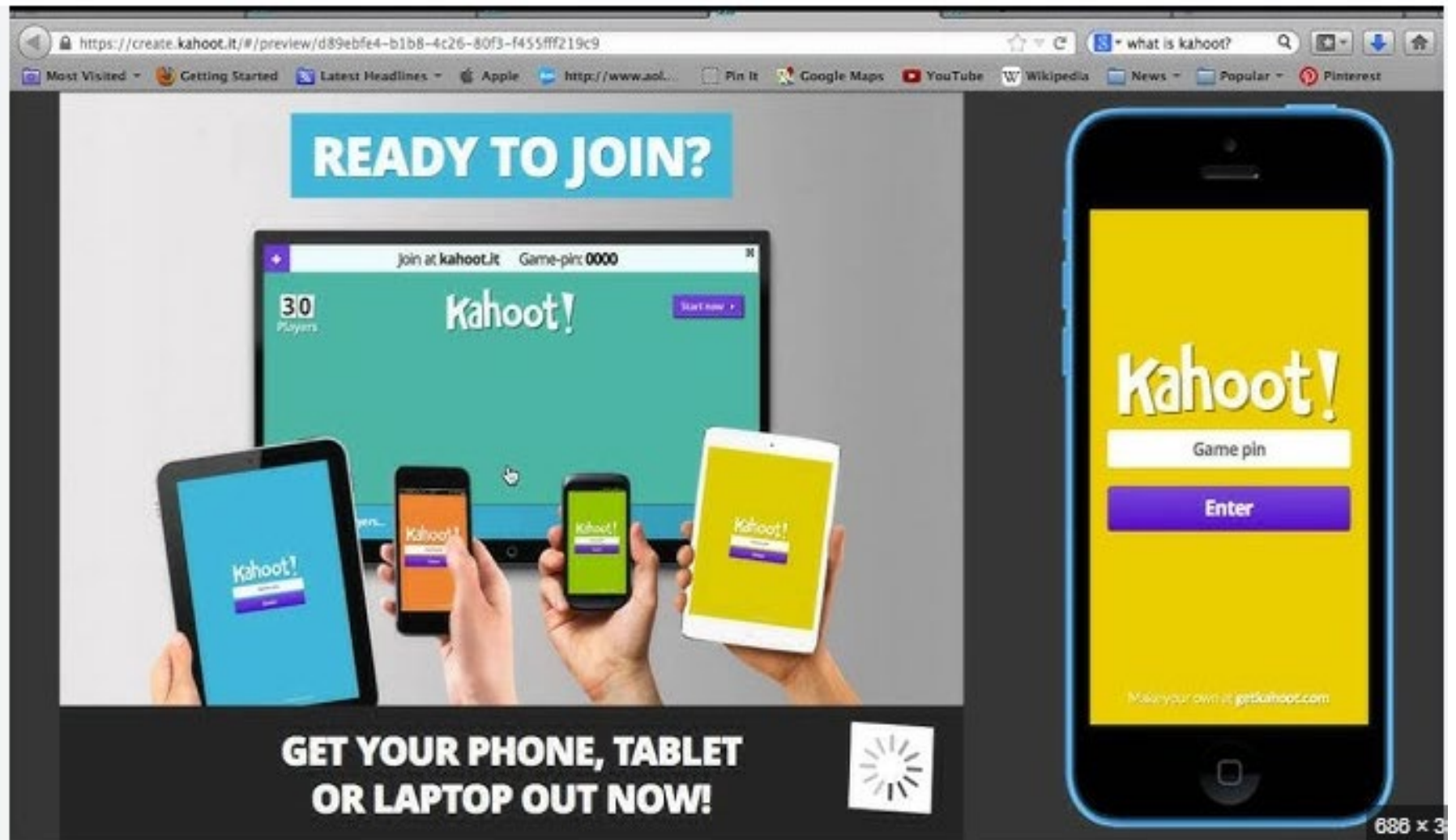
- An **authentication error** could be expected to have a **severe or catastrophic adverse effect**

MAXIMUM **POTENTIAL IMPACTS** FOR EACH ASSURANCE LEVEL.

Potential Impact Categories for Authentication Errors	Assurance Level Impact Profiles 1	Assurance Level Impact Profiles 2	Assurance Level Impact Profiles 3	Assurance Level Impact Profiles 4
Inconvenience, distress, or damage to standing or reputation	Low	Mod	Mod	High
Financial loss or organization liability	Low	Mod	Mod	High
Harm to organization programs or interests	None	Low	Mod	High
Unauthorized release of sensitive information	None	Low	Mod	High
Personal safety	None	None	Low	Mod/High
Civil or criminal violations	None	Low	Mod	High

Red ➔ Potential impact

Kahoot!



The image is a screenshot of a web browser displaying the Kahoot! website. The browser's address bar shows the URL <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>. The browser's toolbar includes links for 'Most Visited', 'Getting Started', 'Latest Headlines', 'Apple', 'http://www.aol...', 'Pin It', 'Google Maps', 'YouTube', 'Wikipedia', 'News', 'Popular', and 'Pinterest'. The main content area features a large blue banner with the text 'READY TO JOIN?'. Below this banner is a laptop screen displaying the Kahoot! interface, which includes the text 'join at kahoot.it', 'Game-pin: 0000', '30 Players', and the Kahoot! logo. In front of the laptop are four mobile devices (two tablets and two smartphones) held by hands, each displaying the Kahoot! interface. At the bottom of the image, there is a black banner with the text 'GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!' and a white loading icon. On the right side of the image, there is a large smartphone displaying the Kahoot! interface, which includes the text 'Kahoot!', 'Game pin', and 'Enter'. At the bottom of the smartphone screen, there is a link 'Make your own at getkahoot.com'. The overall image is a promotional advertisement for Kahoot!

READY TO JOIN?

join at kahoot.it Game-pin: 0000

Kahoot!

30 Players

Start now

GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!

Kahoot!

Game pin

Enter

Make your own at getkahoot.com

688 x 3

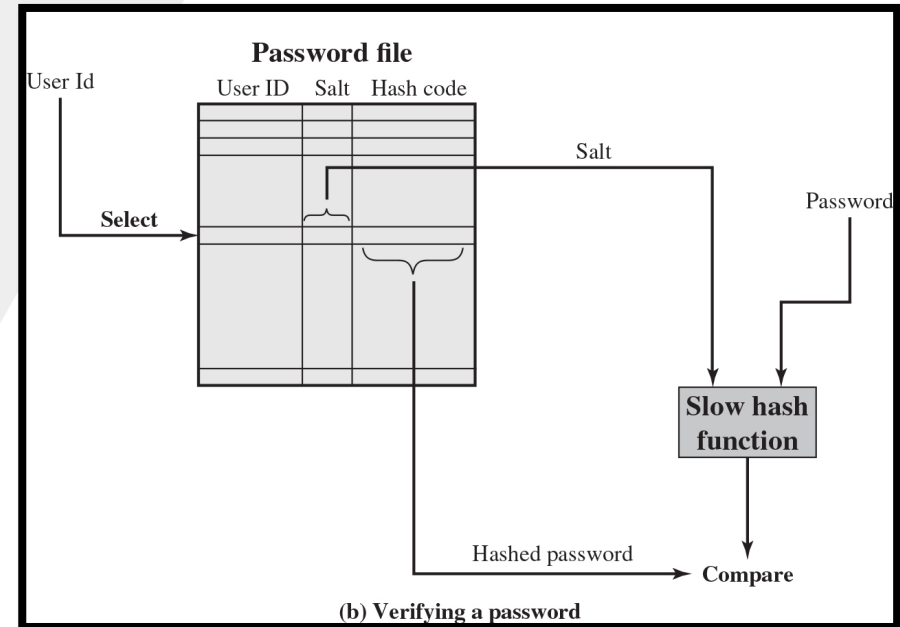
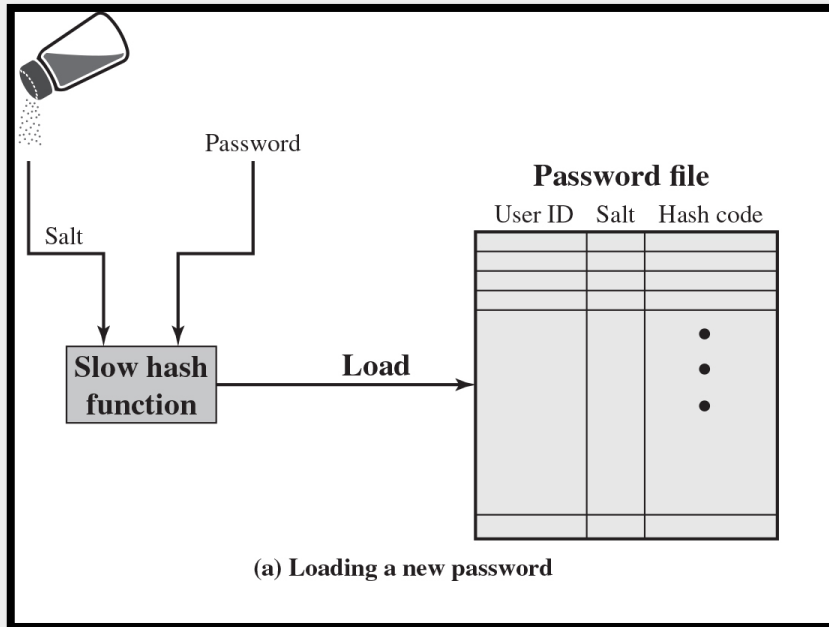
True / False Questions

Level 1 assurance is sufficient when the potential impact of an authentication error is High .	False
If the potential impact of an authentication error is Moderate , then at least Level 2 assurance is required.	True
An authentication system with Level 4 assurance can handle cases where an error has a High potential impact.	True
A Level 2 assurance system can be used for situations where an authentication error has a High potential impact.	False
As the potential impact of authentication errors increases, the required assurance level also increases.	True
Level 3 assurance provides the same level of security as Level 4, making it suitable for all High-impact situations.	False
For an authentication system with only Level 1 assurance, errors are expected to have at most a Low impact.	True
If the potential impact of an authentication failure is Low , then any assurance level (1-4) can be used.	True
A Moderate potential impact means that a Level 1 authentication method is never appropriate.	True
For highly sensitive systems where authentication errors could cause catastrophic damage, Level 4 assurance is required.	True

PASSWORD-BASED AUTHENTICATION

- Widely used line of defense against intruders
 - User provides name/login and password
 - System compares password with the one stored for that specified login
- The user ID:
 - Determines that the user is authorized to access the system
 - **Determines the user's privileges**
 - Is used in discretionary access control

1. **Identify the problem.** The first step in the problem-solving process is to identify the problem. This involves recognizing the issue, understanding its scope, and determining the goal of the solution.



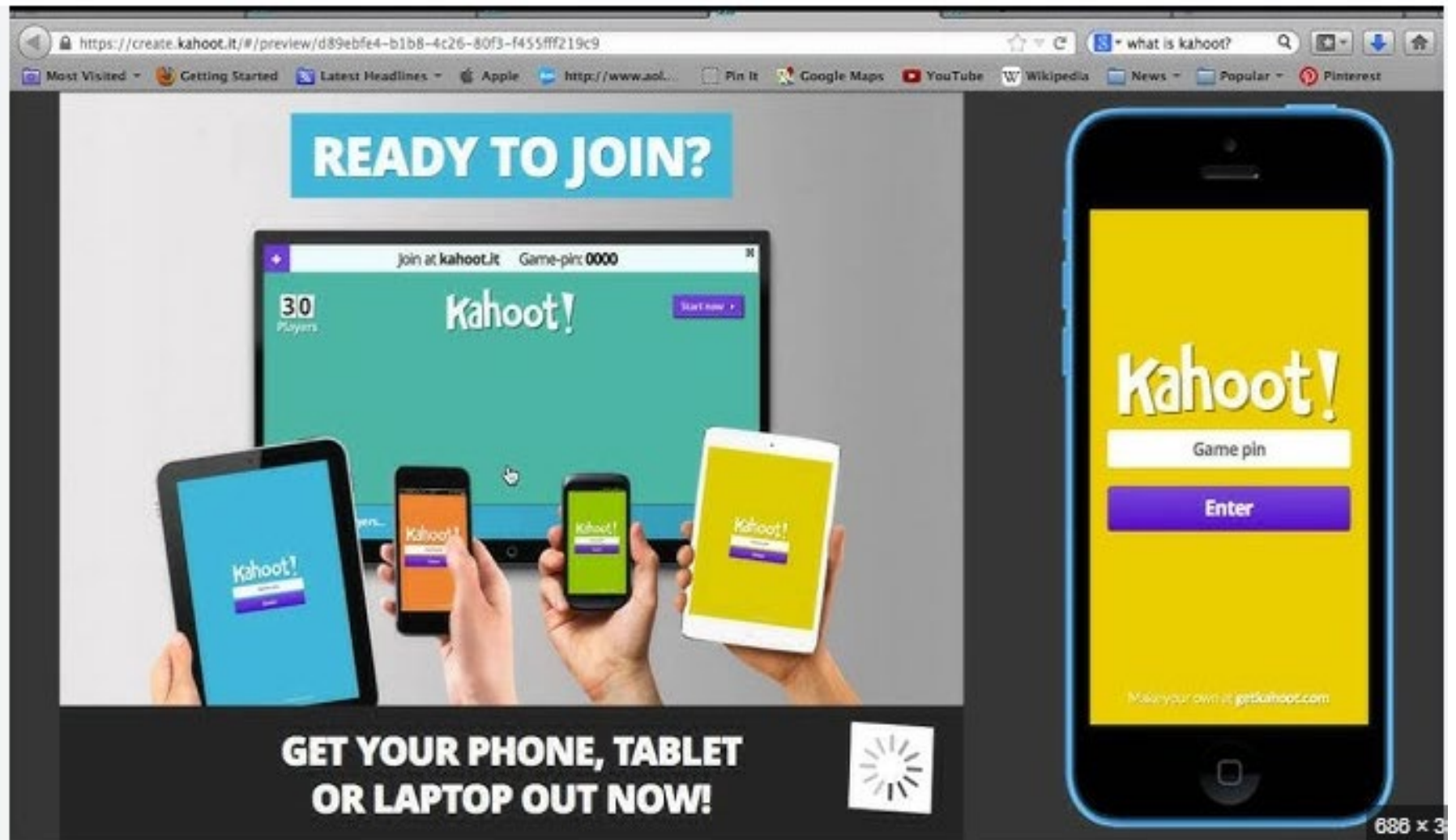
In **cryptography**, a **salt** is random data fed as an additional input to a one-way function that hashes data, a password or passphrase.

Prevents Duplicate Passwords	Increases Security Against Attacks
Ensures that even if two users have the same password, their hashed passwords will differ due to unique salt values, making duplicate passwords invisible in the password file.	Increases attack difficulty by forcing attackers to compute hashes for each password guess with every possible salt , multiplying cracking effort.

PASSWORD CRACKING

- **Dictionary attacks**
 - **Develop a large dictionary of possible passwords and try each against the password file**
 - Each password must be hashed using each salt value and then compared to stored hash values
- **Rainbow table attacks**
 - **Pre-compute tables of hash values for all salts**
 - A mammoth table of hash values
 - Can be countered by using a sufficiently large salt value and a sufficiently large hash length
- **Password crackers exploit the fact that people choose easily guessable passwords**
 - Shorter password lengths are also easier to crack
- **John the Ripper**
 - Open-source password cracker first developed in in 1996
 - Uses a combination of brute-force (tries to guess the password) and dictionary techniques

Kahoot!



The image is a screenshot of a web browser displaying the Kahoot! website. The browser's address bar shows the URL <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>. The browser's toolbar includes various icons and links such as "Most Visited", "Getting Started", "Latest Headlines", "Apple", "http://www.aol...", "Pin It", "Google Maps", "YouTube", "Wikipedia", "News", "Popular", and "Pinterest".

The main content area features a large blue banner with the text "READY TO JOIN?". Below this banner is a laptop screen displaying the Kahoot! interface. The laptop screen shows a green background with the Kahoot! logo, a "Start now" button, and a "Game pin: 0000" field. In front of the laptop, four hands are holding mobile devices (two tablets and two smartphones) that also display the Kahoot! interface. The devices show the Kahoot! logo, a "Game pin" field, and an "Enter" button.

At the bottom of the image, there is a black banner with the text "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!". To the right of this text is a white loading icon (a circle with radiating lines). In the bottom right corner, there is a small text "686 x 3".

Which of the following best describes a dictionary attack?

- A) Precomputing hash values for all possible salt values
- B) Using a large set of potential passwords and testing them against hashed passwords
- C) Exploiting vulnerabilities in password hashing algorithms
- D) Encrypting password files to prevent unauthorized access

How does a rainbow table attack differ from a dictionary attack?

- A) A rainbow table attack precomputes hash values, while a dictionary attack tests passwords in real-time
- B) A dictionary attack is only effective on short passwords, while a rainbow table attack works on all passwords
- C) A rainbow table attack brute-forces passwords, while a dictionary attack uses precomputed hash values
- D) Both attacks use precomputed hash values, but a dictionary attack is faster

What is an effective countermeasure against rainbow table attacks?

- A) Using shorter password lengths
- B) Increasing CPU speed for hashing
- C) Implementing sufficiently large salt values
- D) Encrypting stored passwords with a weak key

What technique does John the Ripper use to crack passwords?

- A) Only brute-force attacks
- B) A combination of brute-force and dictionary techniques
- C) Only dictionary-based attacks
- D) Only exploiting password manager vulnerabilities

PASSWORD SELECTION STRATEGIES

- **User education**
 - Users can be told the importance of using hard to guess passwords and can be provided with guidelines for selecting strong passwords
- **Computer generated passwords**
 - Users have trouble remembering them
- **Reactive password checking**
 - System periodically runs its own password cracker to find guessable passwords
- **Complex password policy**
 - User is allowed to select their own password, however the system checks to see if the password is allowable, and if not, rejects it
 - Goal is to eliminate guessable passwords while allowing the user to select a password that is memorable

PROACTIVE PASSWORD CHECKING

- **Rule enforcement**

- Specific rules that passwords must adhere to

- **Password checker**

- Compile a large dictionary of passwords not to use (a database of hacked passwords)
- Prevents user from using the password

- **Bloom filter**

- A space-efficient probabilistic data structure that is used to test whether an item is a member of a set.
 - Used to build a table based on hash values
 - Check desired password against this table – gives hint to the user but doesn't prevent usage (example: chrome : you are using a password that showed on a breach)

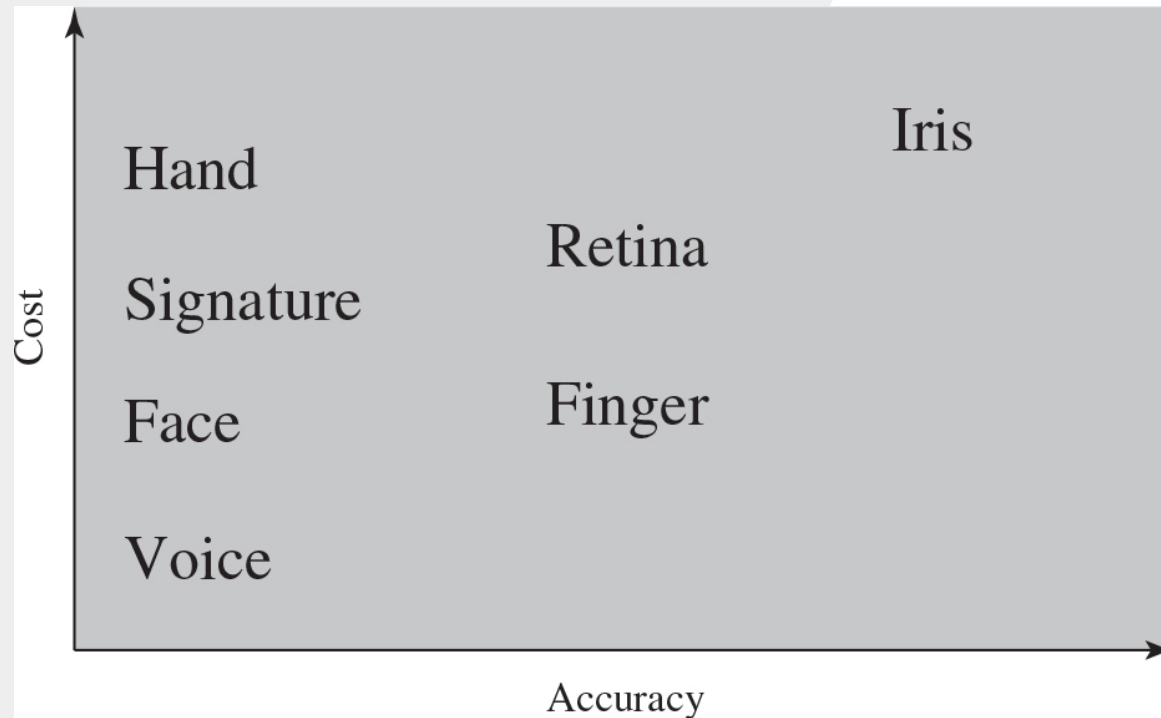
TYPES OF CARDS USED AS TOKENS

Feature	Smart Card	Memory Card
Processing	Has a microprocessor for secure operations.	Stores data only, no processing.
Security	High	Low
Functionality	Authentication, encryption, secure logins.	Basic data storage (e.g., PINs).
Cost	Higher	Lower
Use cases	• Payment cards (credit cards) • Government IDs	• Prepaid phone cards • Some ATM cards (magnetic stripe)

BIOMETRIC AUTHENTICATION

- **Attempts to authenticate an individual based on unique physical characteristics**
 - **Based on pattern recognition**
- Is technically complex and expensive when compared to passwords and tokens
- **Physical characteristics used include:**
 - Facial characteristics
 - Fingerprints
 - Hand geometry
 - Retinal pattern
 - Iris
 - Signature
 - Voice

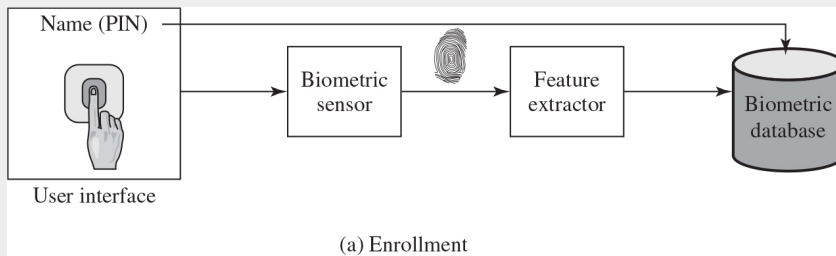
COST VERSUS ACCURACY OF VARIOUS BIOMETRIC CHARACTERISTICS IN USER AUTHENTICATION SCHE



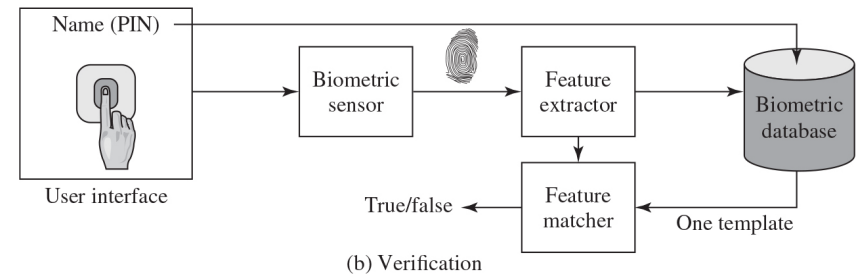
Usually used in combination (multiple methods) not stand alone

A GENERIC BIOMETRIC SYSTEM

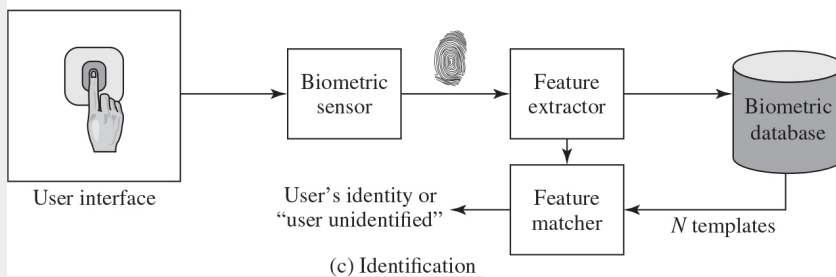
- **Enrollment** creates an association between a user and the user's biometric characteristics. Depending on the application, user authentication either involves **verifying** that a claimed user is the actual user or **identifying** an unknown user.



Enrollment



Verification



Identification

Decided based on the system design

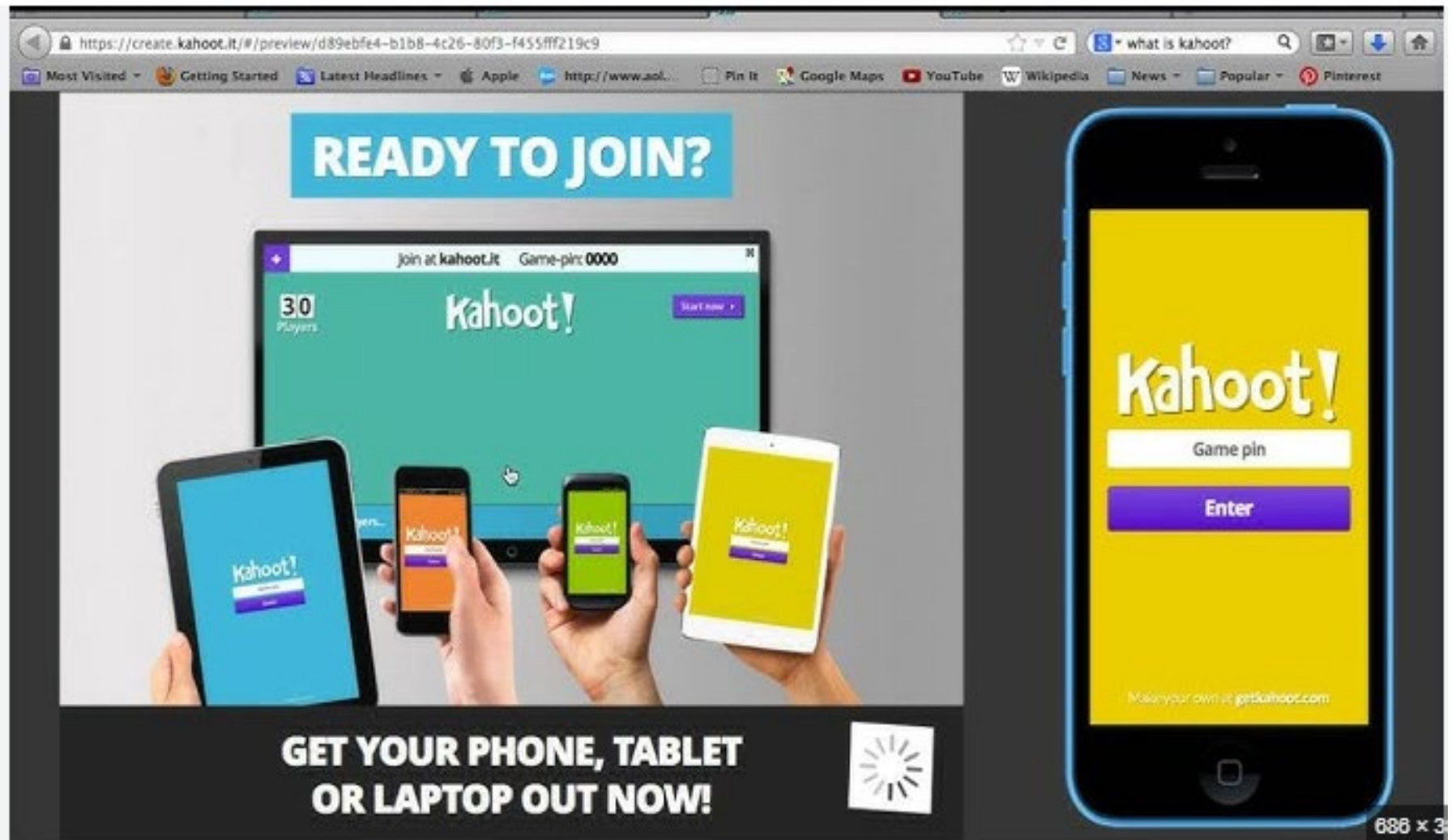
REMOTE USER AUTHENTICATION

- Authentication depends on the organization's security policy
- **Authentication over a network, the Internet, or a communications link is more complex**
- Additional security threats such as:
 - Eavesdropping, capturing a password, replaying an authentication sequence that has been observed
- Generally, rely on some form of a challenge-response protocol to counter threats

AUTHENTICATION SECURITY ISSUES

- **Eavesdropping**: Adversary attempts to learn the password by some sort of attack that involves the physical proximity of user and adversary
- **Host Attacks**: Directed at the user file at the host where passwords, token passcodes, or biometric templates are stored
- **Replay Attack**: When a malicious actor captures and retransmits valid data to achieve fraudulent authentication or execute unauthorized actions in a network (man in the middle attack)
- **Client Attacks**: Adversary attempts to achieve user authentication without access to the remote host or the intervening communications path
- **Trojan Horse**: An application or physical device masquerades as an authentic application or device for the purpose of capturing a user password, passcode, or biometric
- **Denial-of-Service**: Attempts to disable a user authentication service by flooding the service with numerous authentication attempts

Kahoot!



The image is a screenshot of a web browser displaying the Kahoot! website. The browser's address bar shows the URL <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>. The browser's toolbar includes various icons and links such as "Most Visited", "Getting Started", "Latest Headlines", "Apple", "http://www.aol...", "Pin It", "Google Maps", "YouTube", "Wikipedia", "News", "Popular", and "Pinterest".

The main content area features a large blue banner with the text "READY TO JOIN?". Below this banner is a central image of a laptop screen displaying the Kahoot! interface. The laptop screen shows the text "join at kahoot.it", "Game-pin: 0000", "30 Players", and the Kahoot! logo. In front of the laptop, four hands are holding mobile devices (two tablets and two smartphones) that also display the Kahoot! interface. The devices show the Kahoot! logo and a "Start now" button.

At the bottom of the image, there is a black banner with the text "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!". To the right of this text is a white loading icon (a circle with radiating lines). In the bottom right corner, there is a small text "686 x 3".

On the right side of the image, there is a large smartphone screen displaying the Kahoot! mobile app interface. The screen is yellow and features the Kahoot! logo, a "Game pin" input field, and a purple "Enter" button. At the bottom of the screen, there is a small text "Make your own at getkahoot.com".

What distinguishes an eavesdropping attack from other authentication attacks?

- A) It targets stored passwords on a host system
- B) It requires physical proximity to the user**
- C) It modifies authentication responses to bypass security
- D) It floods the authentication service with excessive requests

Which attack involves an adversary capturing and reusing a previously recorded authentication response?

- A) Trojan Horse
- B) Eavesdropping
- C) Replay attack**
- D) Client attack

What is a key characteristic of a Trojan Horse attack?

- A) The attacker floods an authentication service with excessive login attempts
- B) The attacker pretends to be a legitimate application or device to steal credentials**
- C) The attacker modifies network packets to change authentication responses
- D) The attacker intercepts login credentials using physical proximity

A hacker gains unauthorized access to a company's authentication database and attempts to extract stored passwords. This is an example of:

- A) Replay attack
- B) Client attack
- C) Host attack**
- D) Eavesdropping

In which attack does an adversary attempt authentication without directly accessing the host or the communication path?

- A) Denial-of-Service
- B) Client attack**
- C) Replay attack
- D) Eavesdropping

How does a Denial-of-Service (DoS) attack target an authentication system?

- A) By stealing stored passwords from the host system
- B) By repeatedly capturing authentication responses to reuse later
- C) By overwhelming the system with numerous authentication attempts**
- D) By attempting to authenticate without access to the server

USER ACCESS CONTROL DEFINITIONS

N I S T I R 7298 defines access control as:

“The process of granting or denying specific requests to:
(1) obtain and use information and related information processing services
(2) enter specific physical facilities”

R F C 4949 defines access control as:

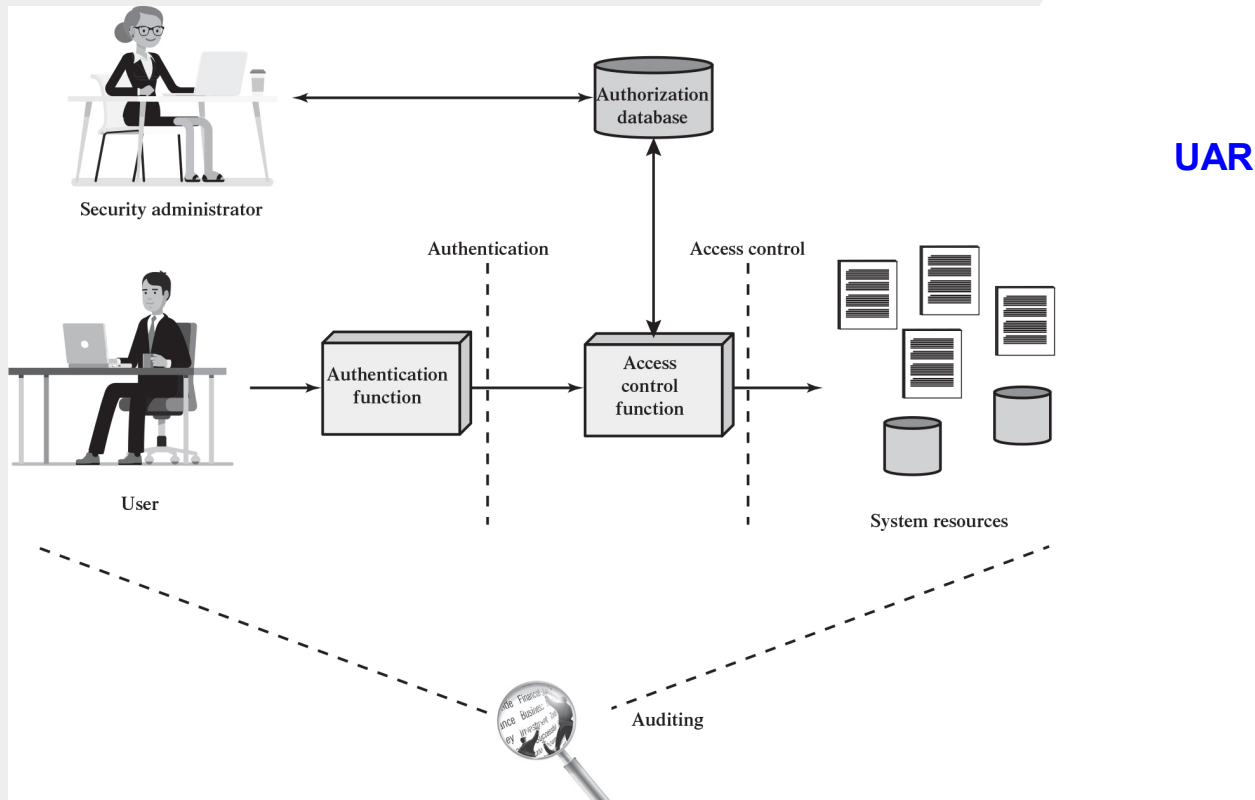
“A process by which use of system resources is regulated according to a security policy and is permitted only by authorized entities (users, programs, processes, or other systems) according to that policy”

ACCESS CONTROL PRINCIPLES

- In a broad sense, all of computer security is concerned with access control
- RFC 4949 defines computer security as:

“**measures that implement and assure security services in a computer system, particularly those that assure access control service**”

FIGURE 4.1 RELATIONSHIP AMONG ACCESS CONTROL AND OTHER SECURITY FUNCTIONS



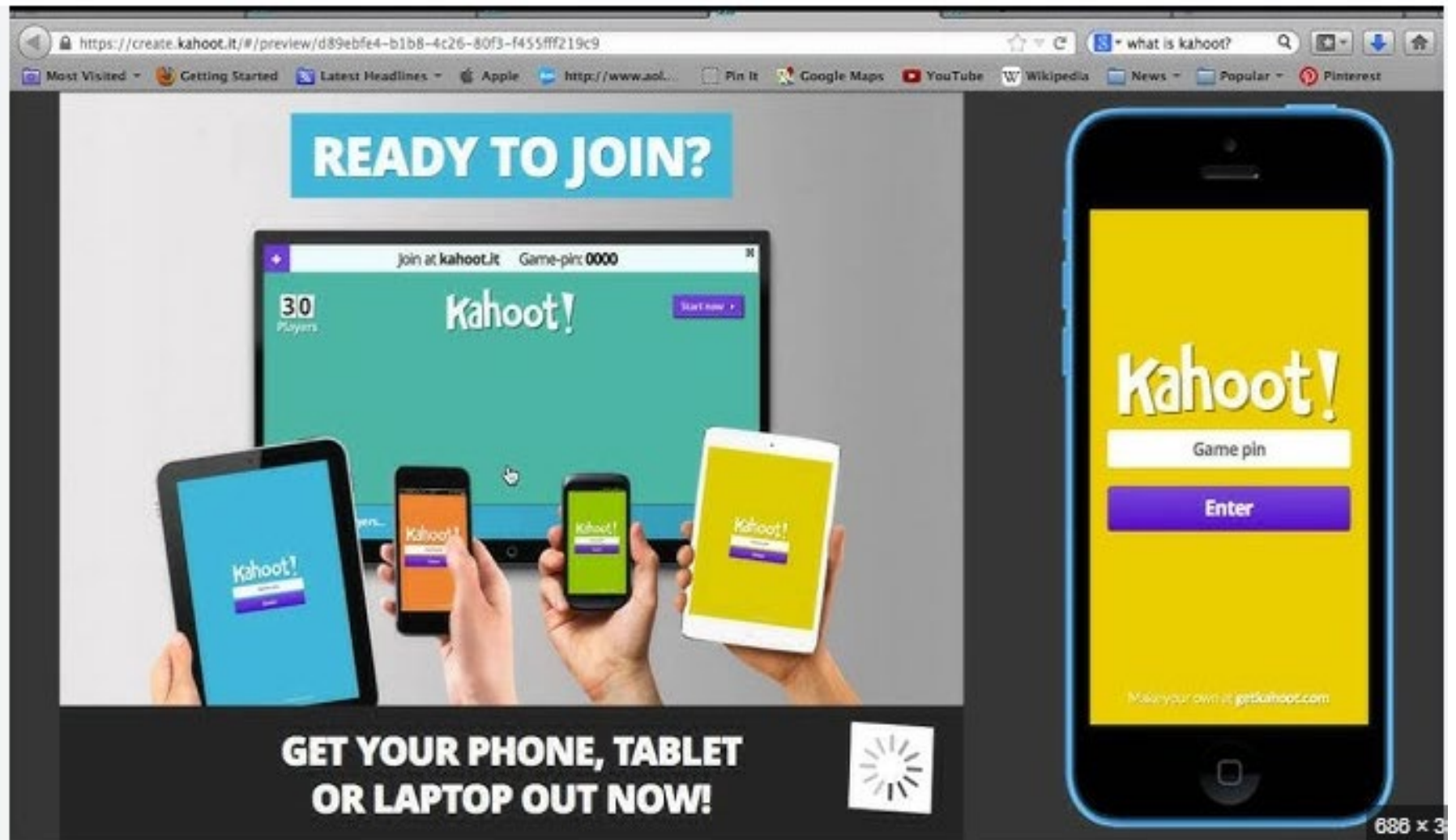
Authorization vs Authentication

Source: Based on [SAND94].

ACCESS CONTROL POLICIES

- *Discretionary access control (DAC)*
 - Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors are (or are not) allowed to do.
 - *Example: Alice shares a file with Bob, granting "write" access. One Drive, Google Drive*
- *Role-based access control (RBAC)*
 - Controls access **based on the roles** that users have within the system and on rules stating what accesses are allowed to users in given roles.
 - *Example: Doctors can edit patient records; receptionists can only schedule appointments.*
- *Mandatory access control (MAC)*
 - Controls access based on comparing security labels with security clearances.
 - *Only users with "Top Secret" clearance can access "Top Secret" documents. Security Clearance (Digital and Physical)*
- *Attribute-based access control (ABAC)*
 - Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions.
 - *Access to a system allowed only during business hours and within the corporate network. Physical location*

Kahoot!



The image displays the Kahoot! website interface within a web browser window and a mobile app interface on a smartphone.

Website Interface:

- URL:** <https://create.kahoot.it/#/preview/d89ebfe4-b1b8-4c26-80f3-f455fff219c9>
- Search Bar:** "what is kahoot?"
- Navigation Bar:** Most Visited, Getting Started, Latest Headlines, Apple, http://www.aol..., Pin It, Google Maps, YouTube, Wikipedia, News, Popular, Pinterest.
- Main Content:**
 - Header:** "READY TO JOIN?"
 - Central Image:** A laptop screen showing the Kahoot! game interface with "30 Players" and "Game-pin: 0000". Below the laptop, four hands hold up a tablet and three smartphones, all displaying the Kahoot! app interface.
 - Footer:** "GET YOUR PHONE, TABLET OR LAPTOP OUT NOW!"

Mobile App Interface:

- Background:** Yellow
- Logo:** "Kahoot!"
- Input Field:** "Game pin"
- Button:** "Enter"
- Footer:** "Make your own at getkahoot.com"

Page Dimensions: 688 x 3

Which access control model allows a user to decide who can access their files and what actions they can perform?

- A) Mandatory Access Control (MAC)
- B) Role-Based Access Control (RBAC)
- C) Discretionary Access Control (DAC)**
- D) Attribute-Based Access Control (ABAC)

A government agency implements a strict access control system where only individuals with "Top Secret" clearance can access "Top Secret" documents. Which access control model is being used?

- A) Role-Based Access Control (RBAC)
- B) Attribute-Based Access Control (ABAC)
- C) Discretionary Access Control (DAC)
- D) Mandatory Access Control (MAC)**

Which access control model assigns permissions based on predefined job functions instead of individual users?

- A) Attribute-Based Access Control (ABAC)
- B) Role-Based Access Control (RBAC)**
- C) Discretionary Access Control (DAC)
- D) Mandatory Access Control (MAC)

A company wants to enforce access restrictions based on multiple conditions, such as user attributes, location, and time of access. Which model best suits this requirement?

- A) Discretionary Access Control (DAC)
- B) Mandatory Access Control (MAC)
- C) Role-Based Access Control (RBAC)
- D) Attribute-Based Access Control (ABAC)**

COMPONENTS OF ACCESS CONTROL: SUBJECTS, OBJECTS, AND ACCESS RIGHTS

Subject

- An entity capable of accessing objects
- Three classes
 - Owner
 - Group
 - World

Object

- A resource to which access is controlled
- Entity used to contain and/or receive information

Access right

- Describes the way in which a subject may access an object
- Could include:
 - *Read, Write, Execute, Delete, Create, Search*

DISCRETIONARY ACCESS CONTROL (DAC)

- Scheme in which an entity may be granted access rights that permit the entity, by its own violation, to enable another entity to access some resource
- Often provided using an access matrix
 - One dimension consists of identified subjects that may attempt data access to the resources
 - The other dimension lists the objects that may be accessed
- Each entry in the matrix indicates the access rights of a particular subject for a particular object

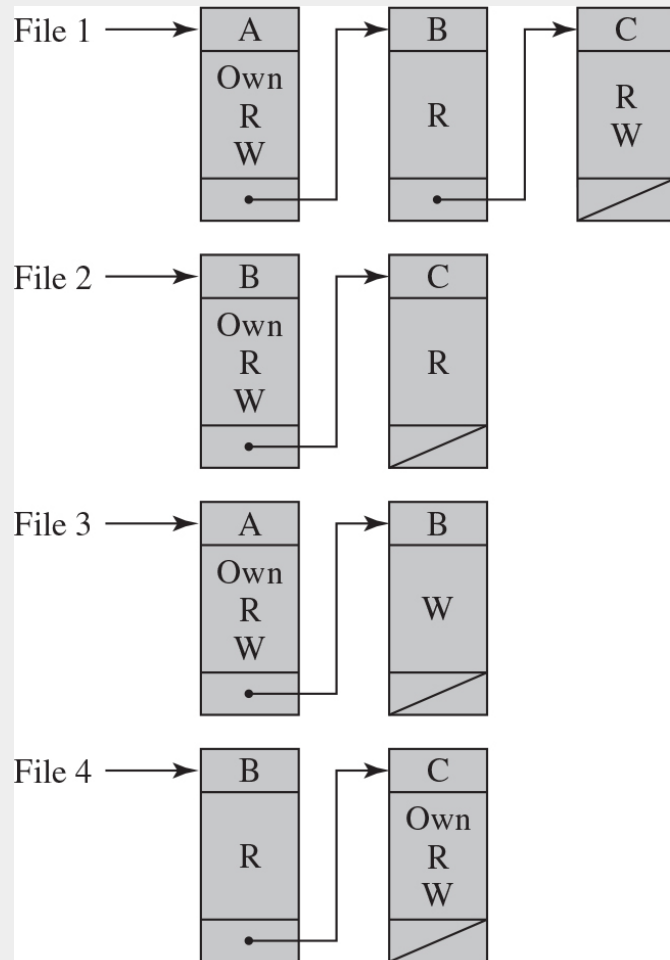
FIGURE 4.2 EXAMPLE OF ACCESS CONTROL STRUCTURES

(1 OF 2)

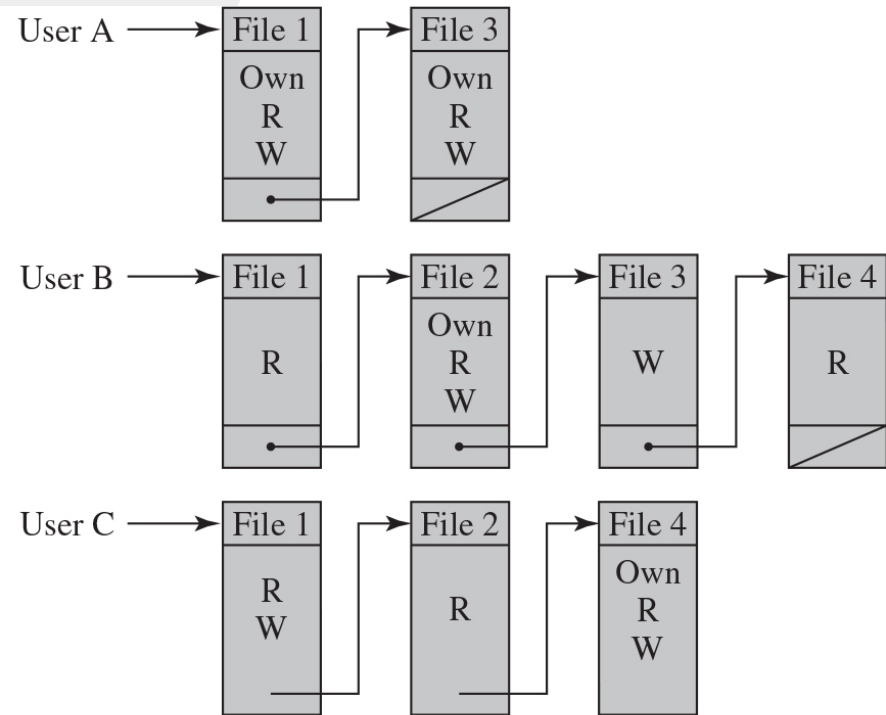
		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix

FIGURE 4.2 EXAMPLE OF ACCESS CONTROL STRUCTURES (2 OF 2)



(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

TABLE 4.2 AUTHORIZATION TABLE FOR FILES IN FIGURE 4.2

Subject	Access Mode	Object
A	Own	File 1
A	Read	File 1
A	Write	File 1
A	Own	File 3
A	Read	File 3
A	Write	File 3
B	Read	File 1
B	Own	File 2
B	Read	File 2
B	Write	File 2
B	Write	File 3
B	Read	File 4

Subject	Access Mode	Object
C	Read	File 1
C	Write	File 1
C	Read	File 2
C	Own	File 4
C	Read	File 4
C	Write	File 4

FIGURE 4.3 EXTENDED ACCESS CONTROL MATRIX

		OBJECTS								
		Subjects			Files		Processes		Disk drives	
		S_1	S_2	S_3	F_1	F_2	P_1	P_2	D_1	D_2
SUBJECTS	S_1	control	owner	owner control	read*	read owner	wakeup	wakeup	seek	owner
	S_2		control		write*	execute			owner	seek*
	S_3			control		write	stop			

* = copy flag set